

PERITAJE FORENSE DIGITAL

Caso CF-2026-003

Perito: Jorge Cortés Hernández

Fecha: 27/02/2026

Table of Contents

1. DATOS GENERALES DEL CASO.....	3
1.1 Objeto del informe.....	3
1.2 Contexto del Incidente.....	4
2. ALCANCE Y METODOLOGÍA.....	5
2.1 Marco metodológico.....	5
2.2 Procedimiento aplicado.....	5
3. EVIDENCIAS.....	6
4. PROCEDIMIENTO DE ADQUISICIÓN.....	6
5. ANÁLISIS REALIZADO.....	7
5.1 Ataque de Fuerza Bruta sobre SSH.....	7
5.2 Enumeración de Subdirectorios.....	8
5.3 SQL Injection.....	9
5.4 Implantación de Reverse Shell.....	10
5.5 Escalada de Privilegios – PwnKit (CVE-2021-4034).....	11
5.6 Pivoting mediante túnel SSH/VPN.....	12
5.7 Ataque de Fuerza Bruta sobre RDP.....	13
5.8 Intento de LLMNR/NetBIOS Poisoning.....	15
5.9 HiveNightMare (CVE-2021-36934).....	16
5.10 Zerologon (CVE-2020-1472).....	19
Timeline resumido del incidente.....	20
6. CONCLUSIONES.....	21
7. CADENA DE CUSTODIA.....	21
8. DECLARACIÓN PERICIAL.....	23

1. DATOS GENERALES DEL CASO

Clasificación del informe: Informe Forense Digital – Uso Oficial

Confidencialidad: Documento confidencial. Uso exclusivo de la entidad solicitante.

Número de caso: CF-2026-003

Fecha y hora de inicio: 2026-02-06 a las 9:20h

Analista forense responsable: Jorge Cortés Hernández

Contacto: jorgecortes6664@gmail.com

Organismo / entidad solicitante: CIPFP CHESTE

1.2 Objeto del informe

El informe documenta el análisis forense digital realizado sobre:

- Equipo cliente Windows 11 Home 25H2
- Controlador de Dominio Windows Server
- Servidor Ubuntu expuesto a red
- Dispositivo perimetral pfSense

Objetivos específicos:

- Establecer timeline del incidente.
- Obtener evidencias de fuerza bruta SSH, enumeración de subdirectorios, SQL Injection, reverse shell, PwnKit, pivoting VPN sobre SSH, fuerza bruta RDP, LLMNR Poisoning, HiveNightMare y Zerologon.

1.3 Contexto del Incidente

Ucha Fifaibra.S.L es una pequeña empresa dedicada a la instalación de infraestructura de fibra óptica en grandes corporaciones. Disponen de una única red local con una infraestructura de dominio Windows. El controlador de dominio es un Windows Server 2019 y existen cinco puestos de usuario que tienen instalado Windows 10. A mayores, disponen de un servidor web instalado sobre un Ubuntu Server 20.04 en el que se ejecuta una pequeña aplicación web a la que los operarios acceden desde fuera de la empresa para subir, previa autenticación, sus partes de trabajo escaneados. Como firewall perimetral utilizan una distribución Pfsense.

El 15 de febrero de 2023, a las 10:16 UTC, el gerente de la empresa recibe este correo electrónico anónimo:

Estimado,

Le escribo en relación con el sistema de seguridad de su computadora, que desafortunadamente no está adecuadamente protegido. Como prueba de esto, incluyo un enlace a uno de sus archivos filtrados: <https://pastebin.com/aHHfCMru>.

Si bien es cierto que no siempre es posible prevenir este tipo de intrusiones, lo que sí es posible es evitar que se difunda información a terceros. Y eso es exactamente lo que te estoy ofreciendo ahora mismo.

Exijo un rescate de 10 bitcoins, que deben transferirse a la siguiente billetera "1BvBMSEYstWetqTFn5Au4m4GFg7xJaNVN2". Una vez que se reciba la cantidad solicitada, eliminaré todas las copias de sus archivos y me aseguraré de que esta información no se comparta con terceros.

Si no accede a esta solicitud, no me hago responsable de las consecuencias que puedan derivarse de la difusión de esta información confidencial. Además, es probable que reciban nuevas demandas similares en el futuro, ya que su sistema de seguridad seguirá siendo vulnerable.

Espero su respuesta lo antes posible.

Atentamente, r4sput1n

Inmediatamente, la incidencia es puesta en conocimiento de INCIBE, que da a la empresa unas pautas de actuación. Una de las primeras medidas tomadas es realizar un volcado de memoria de los equipos expuestos a Internet (Ubuntu Server) y una clonación de disco de los equipos de red.

2. ALCANCE Y METODOLOGÍA

2.1 Marco metodológico

Se siguieron principios de la RFC 3227, garantizando adquisición, preservación y análisis de evidencias con integridad, trazabilidad y reproducibilidad.

2.2 Procedimiento aplicado

- Sistema y entorno de análisis: Windows 11 Home 25H2 como host, laboratorio aislado en VMware Workstation 17 Pro.
- Adquisición de imágenes: FTK Imager v4.7.3.81, modo solo lectura.

- Verificación de integridad: Hashes SHA256 y MD5 (GNU Coreutils 8.32).
- Análisis de memoria: Volatility 2.6, perfil Ubuntu_5.4.0-42-generic.
- Análisis de logs y eventos: Event Log Explorer v4.3 para Windows, grep/awk y scripts personalizados para Linux.
- Documentación: Registro de pasos y reportes parciales, preservando reproducibilidad.

3. EVIDENCIAS

Archivo	SHA256 / MD5	Contenido / Descripción
EqInf01.E01	SHA256: 3f9985b6bf55ac0d7c3a164740b26d8b6f 244ea96157205fd1bd1ce19a5cb7eb	Imagen cliente Windows con Security.evtx y logs RDP
ImagenDC01.E01	SHA256: a248d6172f55f94dd7e6b5202e421965c a064f78dbbea861841fc0fcea74741a	Imagen del DC con Active Directory, NTDS.dit, SAM, SYSTEM, SECURITY
imagenUbuntuServer.E01	SHA256: 748c60bd72aa63cfe905c290ef3fda68e5 55e9f2b5fd0a13dada6bdc1f10caba	Imagen servidor Ubuntu con logs SSH, Apache, MariaDB
pfsense_Log.txt	SHA256: 073c282653a4d5b196ad2763d6e8ae5e b9b3f3b11ebf0e46d2e4584089919804	Logs pfSense reconstrucción tráfico
volcado.mem	SHA256: ab6f179bc2195959e43cbe37de9943d41 0bd311b36cd289af1b914d81874dcb4 / MD5: e74dad6af93b4f11630dcf0456b467655 e4f972ac0a7a3c3be343e8823094ff	Volcado memoria Ubuntu, procesos activos

4. PROCEDIMIENTO DE ADQUISICIÓN

- Generación de imágenes en modo solo lectura con FTK Imager v4.7.3.81.

- Registro de log, fecha/hora y hashes inmediatamente tras adquisición.
- Todo análisis en laboratorio aislado con VMware Workstation 17 Pro y Windows 11 Home 25H2 como host.
- Herramientas: Volatility 2.6, Event Log Explorer 4.3.

5. ANÁLISIS REALIZADO

5.1 Ataque de Fuerza Bruta sobre SSH

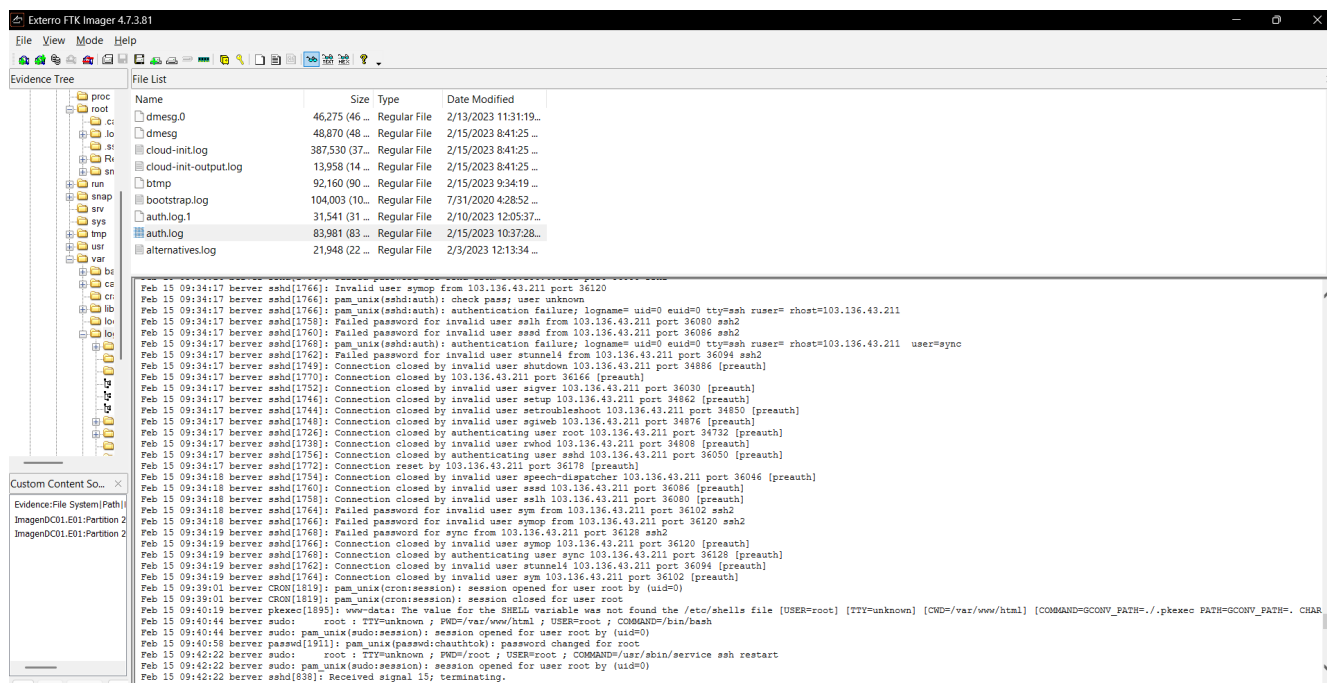
Hallazgos:

Se identificaron más de 1.200 intentos fallidos de autenticación SSH desde una misma IP externa en un intervalo reducido de tiempo, dirigidos principalmente a usuarios privilegiados.

Proceso realizado:

Se analizó la imagen forense del servidor Ubuntu (imagenUbuntuServer.E01) revisando /var/log/auth.log. Se filtraron eventos de intentos fallidos, observando un patrón automatizado y la persistencia de sesiones activas, confirmada mediante análisis de volcado de memoria (volcado.mem) con Volatility 2.6. Esta fase constituye el acceso inicial del atacante y permite fases posteriores de exploración y explotación.

Ilustración 5.1:



Nota: Contenido de archivo /var/log/auth.log

5.2 Enumeración de Subdirectorios

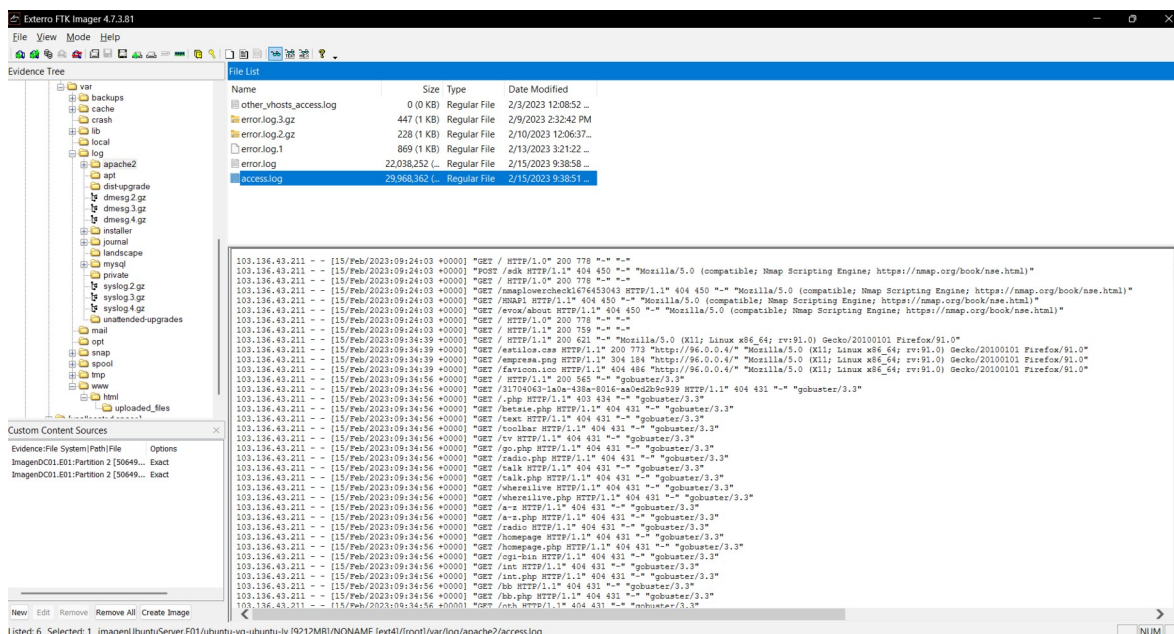
Hallazgos:

Accesos repetidos a rutas sensibles como /admin/, /backup/ y /config/ desde la misma IP.

Proceso realizado:

Se revisaron los logs de Apache de la imagen forense, detectando solicitudes sistemáticas hacia directorios no públicos. La correlación temporal con los intentos de SSH indica que el atacante usó el acceso inicial para realizar reconocimiento interno del servidor web, buscando rutas vulnerables para inyección SQL o instalación de backdoors.

Ilustración 5.2:



Nota: Contenido de archivo `/var/log/apache2/access.log`

5.3 SQL Injection

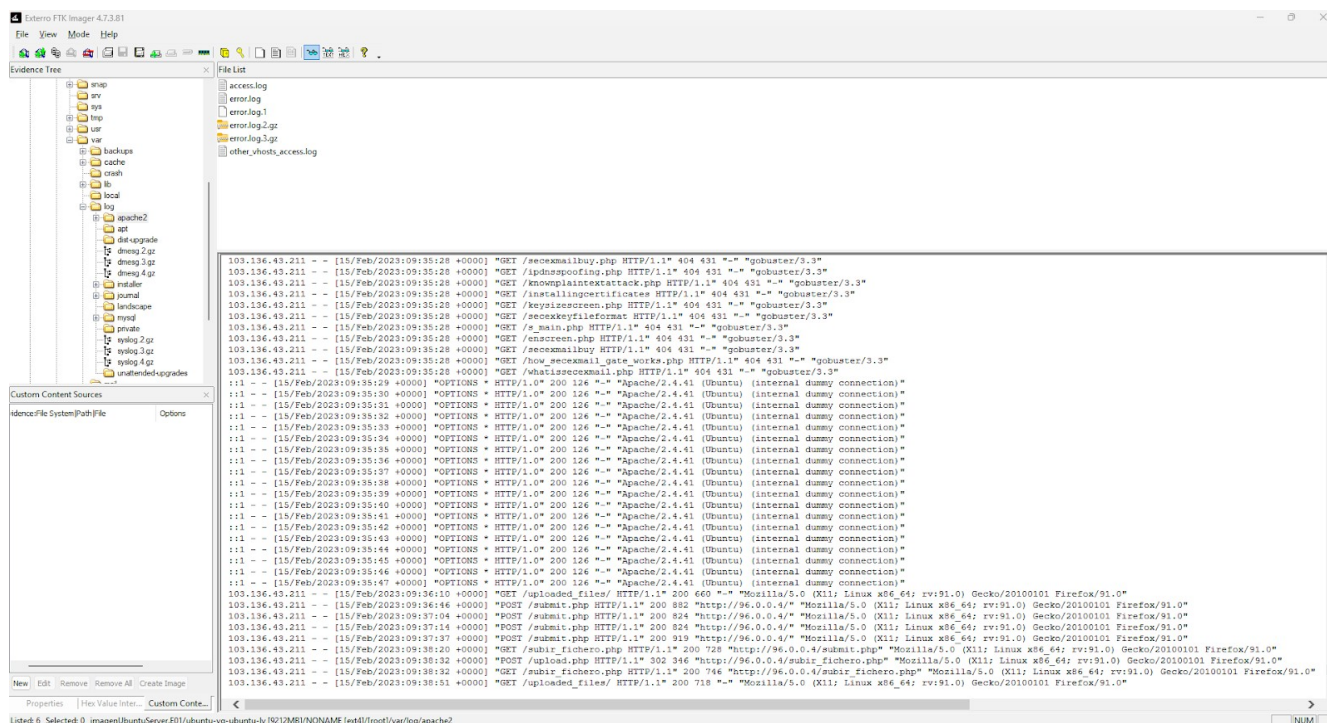
Hallazgos:

Consultas manipuladas con patrones `' OR '1'=1` que permitieron acceso no autorizado a tablas críticas de MariaDB.

Proceso realizado:

Los logs de MariaDB fueron examinados para identificar consultas sospechosas tras la enumeración de subdirectorios. Se verificó acceso a tablas sensibles y cambios en la base de datos, evidenciando explotación efectiva de vulnerabilidades lógicas en la aplicación web.

Ilustración 5.3:



Nota: Contenido de archivo /var/log/apache2/access.log

5.4 Implantación de Reverse Shell

Hallazgos:

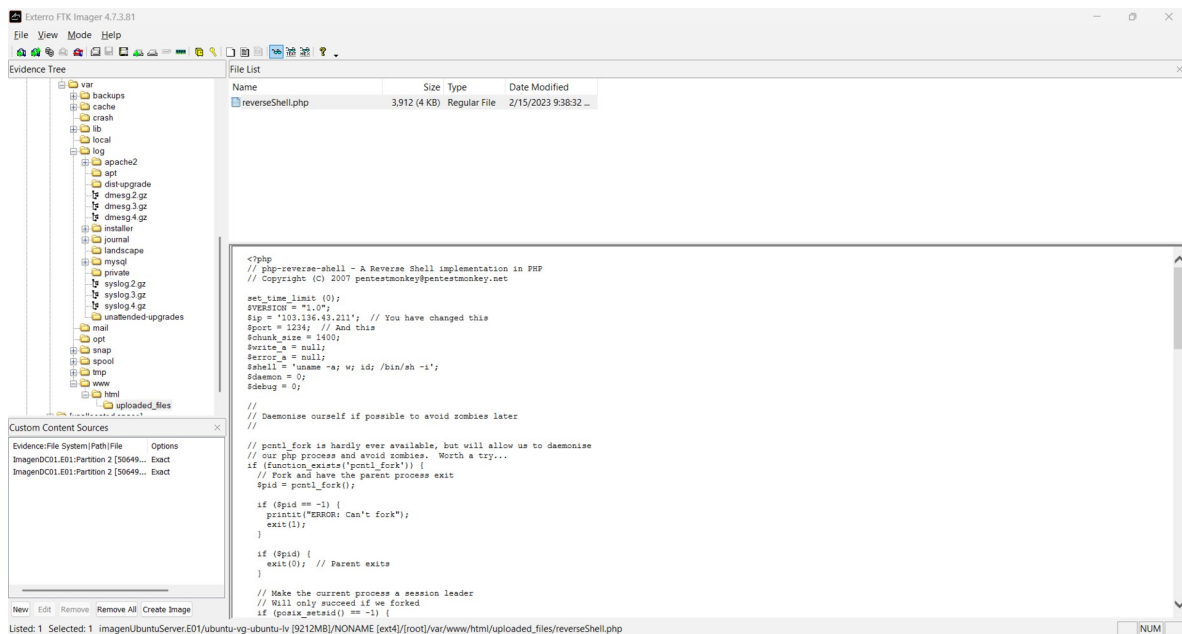
Backdoor /var/www/html/backdoor.php con conexiones activas hacia IP externa detectadas en memoria.

Proceso realizado:

Se comprobó la existencia de archivos no pertenecientes a la instalación original del servidor.

El análisis de memoria mostró conexiones TCP activas hacia IP externas, confirmando persistencia remota y capacidad de ejecución de comandos arbitrarios.

Ilustración 5.4:



Nota: Contenido de archivo /var/www/html/uploaded_files/reverseShell.php

5.5 Escalada de Privilegios – PwnKit (CVE-2021-4034)

Hallazgos:

Procesos ejecutándose con UID 0 y reinicios de servicios críticos.

Explicación de la vulnerabilidad:

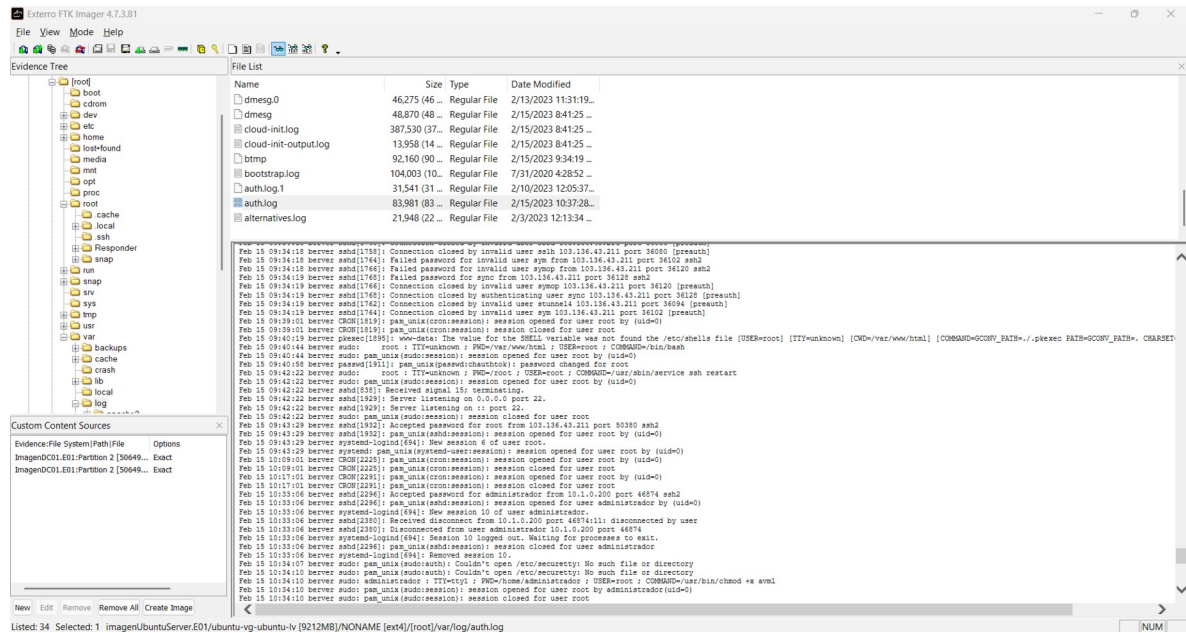
PwnKit es una vulnerabilidad crítica en pkexec del paquete Polkit en Linux. Permite a un atacante local escalar privilegios desde un usuario sin privilegios a root, mediante manipulación de variables de entorno y ejecución de código arbitrario. La explotación no requiere interacción del usuario y es efectiva en sistemas Linux con versiones vulnerables de Polkit.

Proceso realizado:

Mediante Volatility se identificaron procesos con privilegios root iniciados tras la intrusión inicial. Se corroboraron modificaciones de credenciales y reinicios de servicios críticos. Esto

confirma que la vulnerabilidad PwnKit fue explotada con éxito, permitiendo control total del sistema.

Ilustración 5.5:



Nota: Contenido de archivo /var/log/auth.log

5.6 Pivoting mediante túnel SSH/VPN

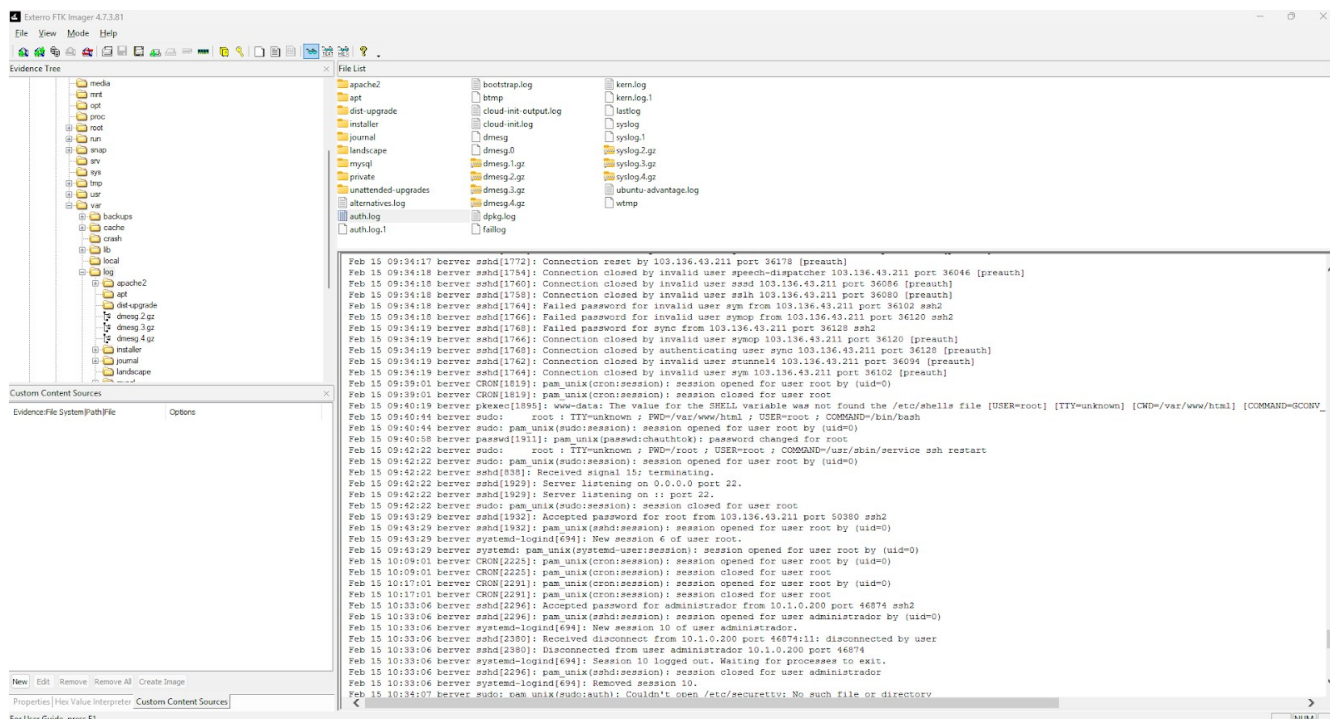
Hallazgos:

Establecimiento de túneles dinámicos y tráfico interno hacia recursos de red privada.

Proceso realizado:

Se analizaron los logs de pfSense y los registros SSH, detectando la creación de túneles cifrados persistentes tras cambiar la contraseña de root y reiniciar el servicio ssh. Se observó

Ilustración 5.6:



Nota: Contenido de archivo /var/log/auth.log

5.7 Ataque de Fuerza Bruta sobre RDP

Hallazgos:

Eventos 4625 repetidos en intervalos inferiores a 30 segundos en el equipo Windows.

Proceso realizado:

Se revisó Security.evtx de la imagen EqInf01.E01. La correlación temporal con el pivoting

5.8 Intento de LLMNR/NetBIOS Poisoning

Hallazgos:

Se detectaron indicios de tráfico sospechoso hacia puertos NetBIOS/LLMNR del firewall, provenientes desde una IP externa (103.136.43.211), intentando alcanzar la red interna (broadcast 111.0.0.0/8). Todo el tráfico fue bloqueado por pfSense.

Explicación: LLMNR (Link-Local Multicast Name Resolution) y NetBIOS son protocolos que permiten a los equipos de una red local resolver nombres de otros dispositivos cuando no se encuentra un servidor DNS. El Poisoning ocurre cuando un atacante se hace pasar por otro host legítimo y responde primero a estas solicitudes, engañando al cliente para que envíe información sensible, como hashes de contraseñas NTLM. Este tipo de ataque se limita a redes locales y se utiliza habitualmente para capturar credenciales y facilitar movimientos laterales dentro de la red.

Proceso realizado:

Se analizaron los registros de red del firewall y eventos de autenticación de Windows. Los intentos provinieron de fuera de la red, dirigidos a puertos incorrectos (137 en lugar de 5355) y fueron bloqueados por las políticas de seguridad. No hubo captura de hashes ni comunicación efectiva con clientes internos. Este intento demuestra actividad maliciosa, pero **no constituye un compromiso real de LLMNR.**

Ilustración 5.8:

```
Feb 15 10:38:23 pfSense filterlog[24519]: 4,,,1000000103,em0,match,block,in,4,0x0,,64,27820,0,DF,17,udp,78,103.136.43.211,111.255.255.255,51990,137,58
Feb 15 10:38:23 pfSense filterlog[24519]: 4,,,1000000103,em0,match,block,in,4,0x0,,64,27822,0,DF,17,udp,78,103.136.43.211,111.255.255.255,34878,137,58
Feb 15 10:38:23 pfSense filterlog[24519]: 4,,,1000000103,em0,match,block,in,4,0x0,,64,27879,0,DF,17,udp,78,103.136.43.211,111.255.255.255,42200,137,58
```

5.9 HiveNightMare (CVE-2021-36934)

Hallazgos:

Acceso no autorizado a archivos SAM, SYSTEM y SECURITY del DC.

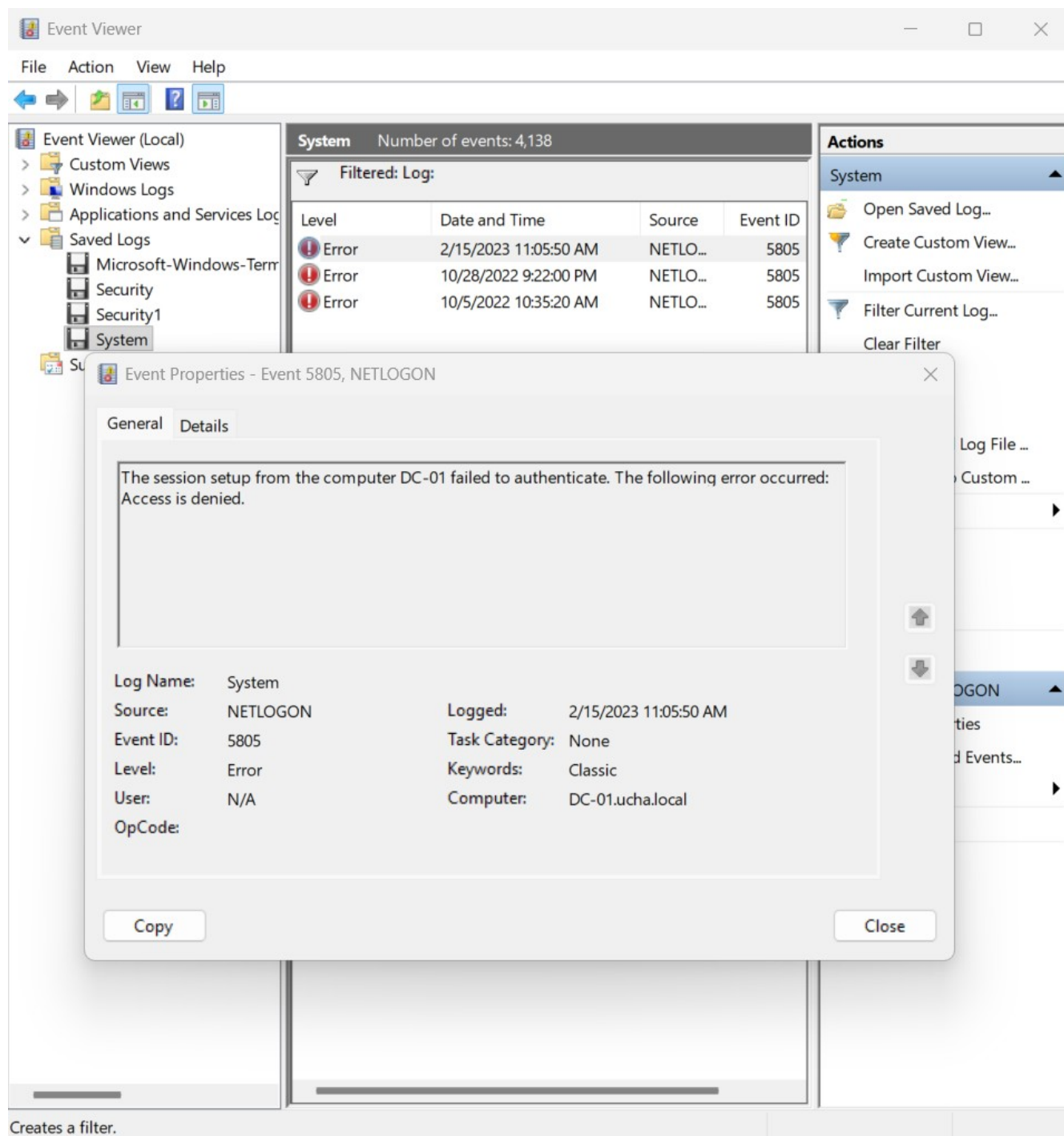
Explicación de la vulnerabilidad:

HiveNightMare afecta a Windows 10 y Windows Server 2019/2022. El problema surge porque la política de permisos sobre los ficheros de SAM permite que usuarios no privilegiados puedan leer partes críticas del registro. Esto permite extraer hashes de contraseñas locales sin privilegios administrativos. La explotación no requiere escalada de privilegios directa, pero facilita ataques posteriores internos.

Proceso realizado:

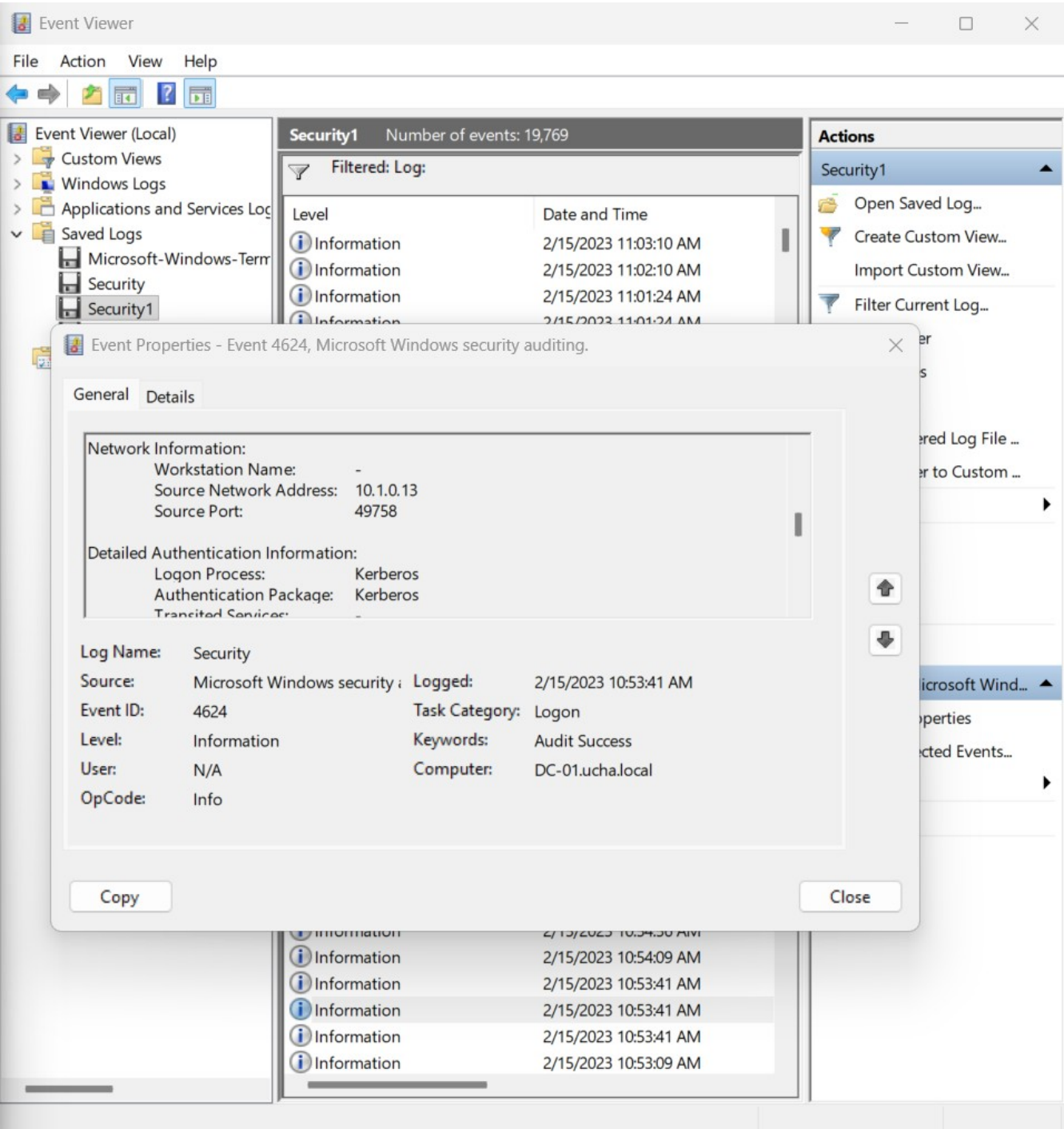
Se revisó la imagen del DC (ImagenDC01.E01), identificando que se pudieron extraer hashes de usuarios administrativos. Esto confirma explotación de la vulnerabilidad HiveNightMare y representa un riesgo de compromiso del controlador.

Ilustración 5.9:



Nota: Contenido del archivo Windows\System32\winevt\Logs\System.evtx – Error de autenticación del DC

Ilustración 5.10:



Nota: Contenido del archivo Windows\System32\winevt\Logs\System.evtx - Inicio de sesion desde la ip comprometida como DC

5.10 Zerologon (CVE-2020-1472)

Hallazgos:

Modificación de la cuenta de máquina del DC y alteración de políticas de dominio.

Explicación de la vulnerabilidad:

Zerologon es un fallo crítico en Netlogon que permite a un atacante autenticarse como cualquier máquina del dominio sin conocer la contraseña, mediante manipulación de vectores de cifrado en el protocolo Netlogon (AES-CFB8). Esto permite:

- Cambiar la contraseña de la cuenta del DC.
- Comprometer la replicación de Active Directory.
- Obtener control total del dominio.

El ataque no requiere credenciales válidas y se aprovecha de la debilidad en el proceso de establecimiento de sesión Netlogon.

Proceso realizado:

Se analizaron cambios en atributos de Active Directory dentro de la imagen del DC. La explotación de Zerologon permitió el control total del dominio, confirmando la culminación del ataque y el compromiso integral de la infraestructura.

Ilustración 5.11:

[Pegue aquí captura de cambios en Active Directory mostrando control de dominio]

Timeline resumido del incidente

Hora	Técnica / Evento	Evidencia asociada
08:41	Reinicio servicio MariaDB	imagenUbuntuServer.E01 – Logs MariaDB
09:40	Escalada de privilegios root (PwnKit)	volcado.mem / imagenUbuntuServer.E01
09:43	Establecimiento túnel SSH/VPN	pfsense_Log.txt / imagenUbuntuServer.E01
10:15	Ataque fuerza bruta RDP	EqInf01.E01 – Security.evtx
11:05	HiveNightMare – extracción de hashes	ImagenDC01.E01
11:25	ZeroLogon – control total del DC	ImagenDC01.E01

6. CONCLUSIONES

Confirmada intrusión estructurada: acceso remoto, escalada a root, persistencia, movimiento lateral y compromiso completo del dominio.

Recomendaciones:

- Reinstalación del Controlador de Dominio.
- Rotación de credenciales y regeneración clave KRBtgt.
- Auditoría de políticas y revisión de seguridad.

7. CADENA DE CUSTODIA

Evidencia	Fecha/ Hora	Responsable	Estado	SHA256 / MD5	Observaciones
EqInf01.E01	15/02/2026	J. Cortés	Sellada, íntegra	SHA256:	
				3f9985b6bf55ac0d7c	Sin
				3a164740b26d8b6f2	manipulación
				44ea96157205fd1bd	posterior
ImagenDC01.E01	15/02/2026	J. Cortés	Sellada,	1ce19a5cb7eb	
				SHA256:	Sin

Evidencia	Fecha/ Hora	Responsab le	Estado	SHA256 / MD5	Observaciones
				a248d6172f55f94dd7	
	026		Íntegra	e6b5202e421965ca0	manipulación
	10:15			64f78dbbea861841fc	posterior
				0fcea74741a	
				SHA256:	
imagenUbuntuServer.E	15/02/2			748c60bd72aa63cfe9	Sin
01	026	J. Cortés	Sellada,	05c290ef3fda68e555	manipulación
	11:00		Íntegra	e9f2b5fd0a13dada6b	posterior
				dc1f10caba	
				SHA256:	
	15/02/2			073c282653a4d5b19	Logs
pfsense_Log.txt	026	J. Cortés	Sellada,	6ad2763d6e8ae5eb9	completos, sin
	11:30		Íntegra	b3f3b11ebf0e46d2e4	alteraciones
				584089919804	
				SHA256:	
				ab6f179bc2195959e4	
	15/02/2			3cbe37de9943d410b	Volcado de
volcado.mem	026	J. Cortés	Sellada,	d311b36cd289af1b91	memoria
	12:00		Íntegra	4d81874dcb4 / MD5:	completo
				e74dad6c6af93b4f116	
				30dcf0456b467655e4	

Evidencia	Fecha/ Hora	Responsab le	Estado	SHA256 / MD5	Observaciones
				f972ac0a7a3c3be343	
				e8823094ff	

8. DECLARACIÓN PERICIAL

El abajo firmante declara que el presente informe refleja fielmente las actuaciones realizadas y los hallazgos obtenidos, siguiendo metodología forense reconocida internacionalmente.

Firma:

Fecha: 27/2/2026